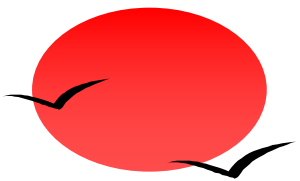


系统架构设计师

系统架构基础篇

第9章 信息安全基础知识

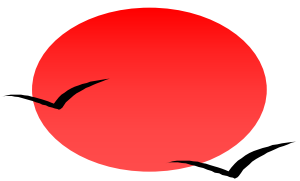
讲师：诸葛老师



本章学习建议

- 根据考试大纲，本章主要考查系统架构设计师**单选题**，预计考**3分**左右。对应第二版教材第4章，常考点有：信息安全基本要素、信息安全技术等。





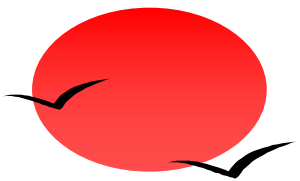
9.1 信息安全基础知识-9.1.1 信息安全的概念

- 信息安全包括5个基本要素：

- (1) **机密性**：确保信息**不暴露给未授权的**实体或进程。
- (2) **完整性**：只有得到允许的人才能修改数据，并且能够**判别出数据是否已被篡改**。
- (3) **可用性**：得到授权的实体**在需要时可访问数据**，即攻击者不能占用所有的资源而阻碍授权者的工作。
- (4) **可控性**：可以**控制授权范围内的信息流向及行为方式**。
- (5) **可审查性**：对出现的**信息安全问题提供调查的依据和手段**。

- 信息安全的范围包括4个安全：

- (1) **设备安全**：信息系统设备的安全是信息系统安全的**首要问题**，是信息系统安全的物质基础，它包括3个方面：设备的稳定性、可靠性和可用性。

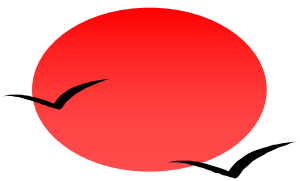


9.1 信息安全基础知识-9.1.1 信息安全的概念

(2) **数据安全**：数据安全即采取措施确保数据免受未授权的泄露、篡改和毁坏，包括3个方面：数据的秘密性、完整性和可用性。

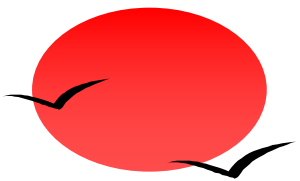
(3) **内容安全**：内容安全是信息安全在政治、法律、道德层次上的要求，包括3个方面：信息内容政治上健康、符合国家法律法规和符合道德规范。

(4) **行为安全**：信息系统的服务功能是指最终通过行为提供给用户，确保信息系统的行为安全，才能最终确保系统的信息安全。行为安全的特性包括：行为的秘密性、完整性和可控性。



9.1.2 信息存储安全

- 信息的存储安全包括信息使用的安全、系统安全监控、计算机病毒防治、数据的加密和防止非法的攻击等。
 - (1) 信息使用的安全。包括用户的标识与验证、用户存取权限限制。
 - (2) 系统安全监控。系统必须建立一套安全监控系统，全面监控系统的活动，并随时检查系统的使用情况，一旦有非法入侵者进入系统，能及时发现并采取相应措施，确定和填补安全及保密的漏洞。还应当建立完善的审计系统和日志管理系统，利用日志和审计功能对系统进行安全监控。
 - (3) 计算机病毒防治。计算机网络服务器必须加装网络病毒自动检测系统，以保护网络系统的安全，防范计算机病毒的侵袭，并且必须定期更新网络病毒检测系统。



9.1.3 网络安全

■ 1. 网络安全隐患

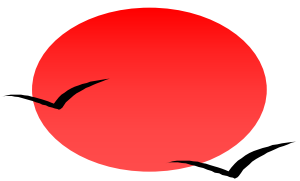
网络安全隐患体现在：物理安全性、软件安全漏洞、不兼容使用安全漏洞、选择合适的安全哲理。

■ 2. 网络安全威胁

网络安全威胁表现在：非授权的访问、信息泄露或丢失、破坏数据完整性、拒绝服务攻击、利用网络传播病毒。

■ 3. 安全措施的目标

安全措施的目标包括：访问控制、认证、完整性、审计、保密。



本节练习

- (1)在进行软件系统安全性分析时，_____保证信息不泄露给未授权的用户、实体或过程；完整性保证信息的完整和准确，防止信息被非法修改；_____保证对信息的传播及内容具有控制的能力，防止为非法者所用。

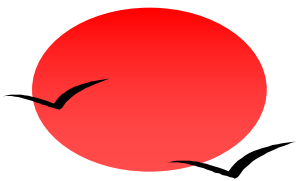
- | | | | |
|---------|---------|-------|-------|
| ■ A.完整性 | B.不可否认性 | C.可控性 | D.机密性 |
| ■ A.完整性 | B.安全审计 | C.加密性 | D.可控性 |

- 答案：D D

- 解析：（1）**机密性**：确保信息**不暴露给未授权的**实体或进程。（2）**完整性**：只有得到允许的人才能修改数据，并且能够**判别出数据是否已被篡改**。（3）**可用性**：得到授权的实体**在需要时可访问数据**，即攻击者不能占用所有的资源而阻碍授权者的工作。（4）**可控性**：可以**控制授权范围内的信息流向及行为方式**。（5）**可审查性**：对出现的**信息安全问题提供调查的依据和手段**。



- 答案: B B



9.2 信息安全系统的组成框架-9.2.1 技术体系

■ 从实现技术上来看，信息安全系统涉及以下技术：

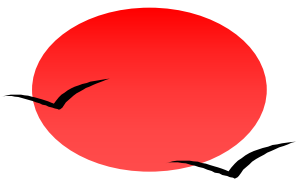
(1) 基础安全设备包括密码芯片、加密卡、身份识别卡等，此外还涵盖运用到物理安全的物理环境保障技术，建筑物、机房条件及硬件设备条件满足信息系统的机械防护安全，通过对电力供应设备以及信息系统组件的抗电磁干扰和电磁泄漏性能的选择性措施达到相应的安全目的。

(2) 计算机网络安全指信息在网络传输过程中的安全防范，用于防止和监控未经授权破坏、更改和盗取数据的行为。通常涉及物理隔离，防火墙及访问控制，加密传输、认证、数字签名、摘要，隧道及VPN技术，病毒防范及上网行为管理，安全审计等实现技术。

(3) 操作系统安全是指操作系统的无错误配置、无漏洞、无后门、无特洛伊木马等，能防止非法用户对计算机资源的非法存取，一般用来表达对操作系统的安全需求。操作系统的安全机制包括标识与鉴别机制、访问控制机制、最小特权管理、可信通路机制、运行保障机制、存储保护机制、文件保护机制、安全审计机制，等等。

(4) 数据库安全可粗略划分为数据库管理系统安全和数据库应用系统安全两个部分，主要涉及物理数据库的完整性、逻辑数据库的完整性、元素安全性、可审计性、访问控制、身份认证、可用性、推理控制、多级保护以及消除隐通道等相关技术。

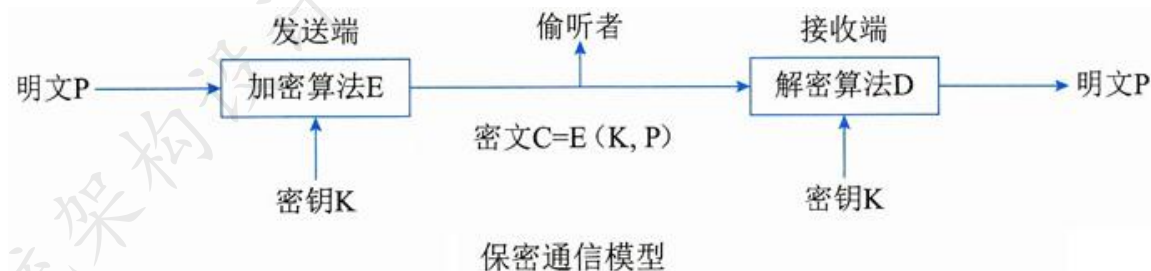
(5) 终端安全设备从电信网终端设备的角度分为电话密码机、传真密码机、异步数据密码机等。



9.3 信息加解密技术-9.3.1 数据加密

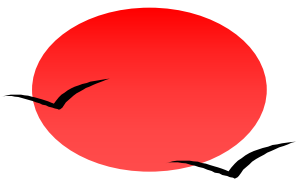
■ 一个密码系统，通常简称为密码体制(Cryptosystem)，由五部分组成：

- (1) 明文空间P，它是全体明文的集合。
- (2) 密文空间C，它是全体密文的集合。
- (3) 密钥空间K，它是全体密钥的集合。
- (4) 加密算法E，它是一组由P至C的加密变换。
- (5) 解密算法D，它是一组由C到P的解密变换。



发送端把明文P用加密算法E和密钥K加密，变换成密文C，即 $C=E(K,P)$ ；

接收端利用解密算法D和密钥K对密文C解密得到明文P，即 $P=D(K,C)$ 。

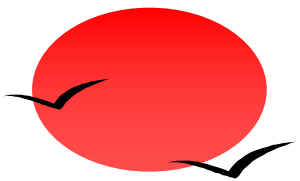


9.3.2 对称加密技术

- 对称加密，采用对称密码编码技术，加密和解密的密钥相同，不公开加密算法。优点是加密快，加密过程简单。缺点是加密强度不高（只有一个密钥），密钥分发困难，保密性较差。

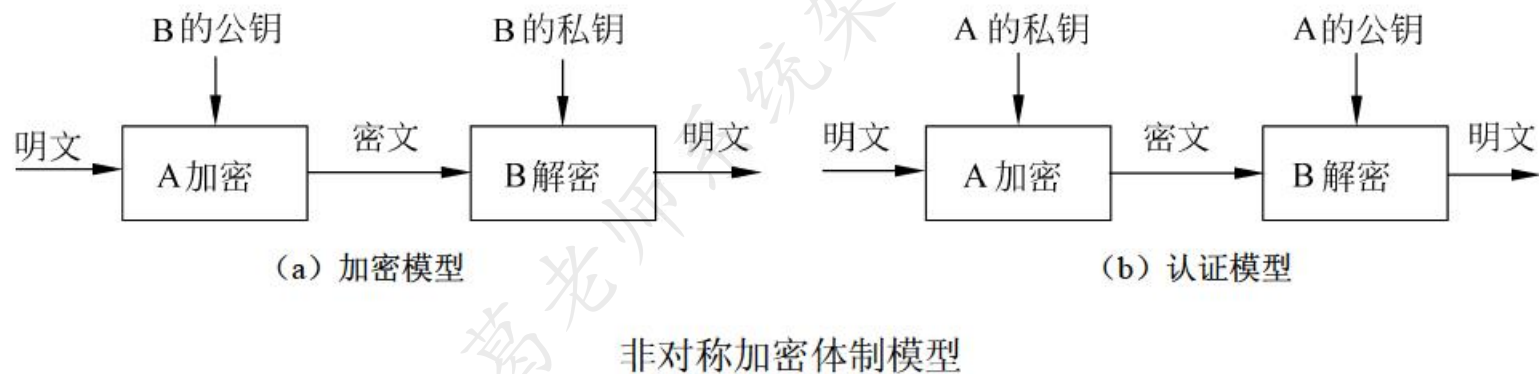
常见对称加密算法：DES、3DES、AES、RC-5、IDEA。

诸葛老师系统架构设计



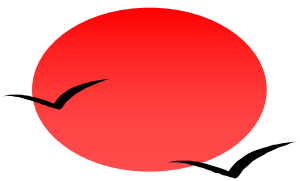
9.3.3 非对称加密技术

- 非对称加密算法需要两个不同的密钥：公开密钥(Publickey)和私有密钥(Privatekey)。公开密钥与私有密钥是一对，如果用公开密钥对数据进行加密，只有用对应的私有密钥才能解密；如果用私有密钥对数据进行加密，那么只有用对应的公开密钥才能解密。公钥体系也就是公开加密算法，即非对称加密。



优点是无须交换密钥，保密性较好。缺点是仅适用少量数据加密，加密速度慢、时间长。常用来加密对称加密算法的密钥。（数字信封的原理）

常见非对称加密算法：RSA、DSA、ECC。



9.3.4 数字签名

■ 对称加密技术与非对称加密技术的应用

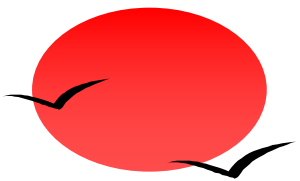
数字加密与数字 签名过程对比

数字加密的主要过程：

- (1) 当信息发送者需要发送信息时，首先生成一个对称密钥，用该对称密钥加密要发送的报文；
- (2) 信息发送者用信息接收者的公钥加密上述对称的密钥；
- (3) 信息发送者将上述两个步骤的结果集合在一起传给信息接收者，称为数字信封；
- (4) 信息接收者使用自己的私钥解密被加密的对称密钥，再用此对称密钥解密被发送方加密的密文，最后得到真正的原文。

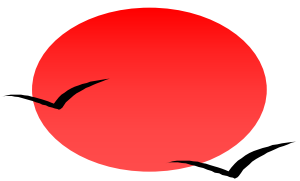
数字签名的主要过程：

- (1) 信息发送者使用一个单项散列函数（Hash函数）对信息生成信息摘要；
- (2) 信息发送者使用自己的私钥签名信息摘要；
- (3) 信息发送者把信息本身与已签名的信息摘要一起发送出去；
- (4) 信息接受者使用与发送者相同的单项散列函数（Hash函数）对接收的信息生成新的信息摘要，再使用发送者的公钥对信息摘要进行验证，以确认信息发送者的身份和信息是否被修改过。



9.3.4 数字签名

- 数字信封运用了对称加密技术和非对称加密技术，本质是使用对称密钥加密数据，非对称密钥加密对称密钥，解决了对称密钥的传输问题。
- 信息摘要的特点：无论数据多长，都会产生固定长度的信息摘要；任何不同的输入数据，都会产生不同的信息摘要；单向性，即只能由数据生成信息摘要，不能由信息摘要还原数据。常见的信息摘要算法：MD5(产生128位的输出)、SHA-1(安全散列算法，产生160位的输出，安全性更高)。
- 数字签名，用发送方的私钥签名，用发送方的公钥验证消息的真实性，发送方不可否认。



9.3.5 公钥基础设施PKI

- **公钥基础设施**（Public Key Infrastructure, **PKI**）：是以**非对称加密技术为基础**，以数据机密性、完整性、身份认证和行为不可抵赖性为安全目的，来实施和提供安全服务的具有普适性的安全基础设施。

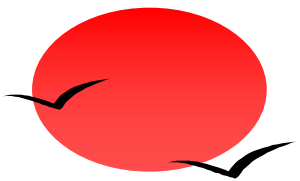
- **1. 数字证书**

一个数据结构，是一种由一个**可信任的权威机构签署的信息集合**。在不同的应用中有不同的证书。如X.509证书必须包含下列信息：(1)版本号(2)序列号(3)签名算法标识符(4)认证机构(5)有效期限(6)主题信息(7)认证机构的数字签名(8)公钥信息。

公钥证书主要用于确保公钥及其与用户绑定关系的安全。这个公钥就是证书所标识的那个主体的合法的公钥。**任何一个用户只要知道签证机构的公钥，就能检查对证书签名的合法性**。如果检查正确，那么用户就可以相信那个证书所携带的公钥是真实的，而且这个公钥就是证书所标识的那个主体合法的公钥。例如驾照。

- **2. 签证机构CA**

负责**签发证书、管理和撤销证书**。是所有注册用户所信赖的权威机构，CA在给用户签发证书时**要加上自己的数字签名**，以保证证书信息的真实性。任何机构可以用**CA的公钥**来验证该证书的合法性。



本节练习

- (3)在安全通信中，S将所发送的信息使用_____进行数字签名，T收到该消息后可利用_____验证该消息的真实性。

- | | | | |
|----------|--------|--------|--------|
| ■ A.S的公钥 | B.S的私钥 | C.T的公钥 | D.T的私钥 |
| ■ A.S的公钥 | B.S的私钥 | C.T的公钥 | D.T的私钥 |

- 答案：B A

- 解析：

数字加密与数字签名过程对比

数字加密的主要过程：

- (1) 当信息发送者需要发送信息时，首先生成一个对称密钥，用该对称密钥加密要发送的报文；
- (2) 信息发送者用信息接收者的公钥加密上述对称的密钥；
- (3) 信息发送者将上述两个步骤的结果集合在一起传给信息接收者，称为数字信封；
- (4) 信息接收者使用自己的私钥解密被加密的对称密钥，再用此对称密钥解密被发送方加密的密文，最后得到真正的原文。

数字签名的主要过程：

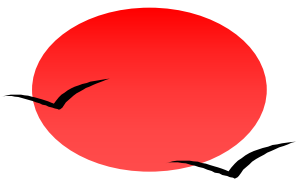
- (1) 信息发送者使用一个单项散列函数（Hash函数）对信息生成信息摘要；
- (2) 信息发送者使用自己的私钥签名信息摘要；
- (3) 信息发送者把信息本身与已签名的信息摘要一起发送出去；
- (4) 信息接受者使用与发送者相同的单项散列函数（Hash函数）对接收的信息生成新的信息摘要，再使用发送者的公钥对信息摘要进行验证，以确认信息发送者的身份和信息是否被修改过。



- ### D.验证该网站的真伪

- 解析：CA 证书是一种数字证书，既可以验证网站的身份，又可以对敏感信息进行加密，这样任何密码、地址或信用卡号都不会被预期接收者以外的任何人拦截或读取。部署 CA 证书后，可以通过验证 HTTPS 中的 CA 证书信息，确认网站的真实身份，增强用户识别正确网站信息，避免用户点击了假冒网站而上当受骗。通过 CA 证书加密层，也可以对传输的数据进行加密和解密，确保数据在传输过程中的安全，保障数据的完整性。

用户可以使用 CA 的公钥对证书上的签名进行验证，一旦验证通过，该证书就被认为是有效的，从而该验证网站的真伪，并不能验证用户的真伪。



9.4 访问控制技术

■ 1. 访问控制的基本模型

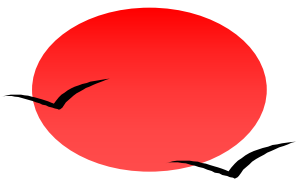
访问控制是指主体依据某些控制策略或权限对客体本身或是其资源进行的不同授权访问。访问控制包括3个要素，即主体、客体和控制策略。

访问控制包括认证、控制策略实现和审计3方面的内容。

■ 2. 访问控制的实现技术

(1) 访问控制矩阵（Access Control Matrix, ACM）。是通过矩阵形式表示访问控制规则和授权用户权限的方法。主体作为行，客体作为列。

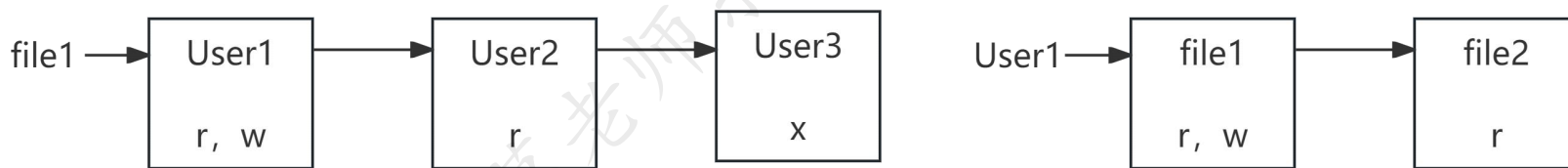
	file1	file2	file3
User1	rw		rw
User2	r	rwX	x
User3	x	r	



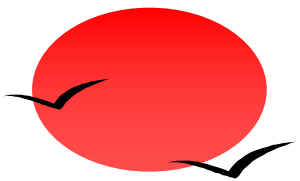
9.4 访问控制技术

(2) 访问控制表(ACL)。是目前**最流行、使用最多**的访问控制实现技术。每个客体有一个访问控制表，是系统中每一个有权访问这个客体的主体的信息。这种实现技术实际上是按列保存访问矩阵。

(3) 能力表。对应于访问控制表，这种实现技术实际上是**按行保存访问矩阵**。每个主体有一个能力表，是该主体对系统中每一个客体的访问权限信息。使用能力表实现的访问控制系统可以很方便地查询某一个主体的所有访问权限。



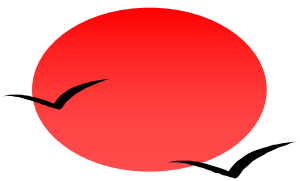
(4) 授权关系表。**每一行(或者说元组)就是访问矩阵中的一个非空元素，是某一个主体对应于某一个客体的访问权限信息**。如果授权关系表按主体排序，查询时就可以得到能力表的效率；如果按客体排序，查询时就可以得到访问控制表的效率。



9.5 信息安全的抗攻击技术-9.5.1 密钥的选择

■ 1. 密钥的选择

为对抗攻击者的攻击，密钥生成需要考虑3个方面的因素：**增大密钥空间、选择强钥(复杂密钥)、密钥的随机性(使用随机数)。**



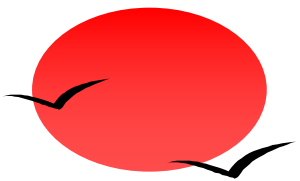
9.5.2 拒绝服务攻击与防御

- **拒绝服务攻击DoS** (Denial of Service) 的主要企图是借助于网络系统或网络协议的缺陷和配置漏洞进行网络攻击，使网络拥塞、系统资源耗尽或者系统应用死锁，妨碍目标主机和网络系统对正常用户服务请求的及时响应，造成服务的性能受损甚至导致服务中断。目前常见的拒绝服务攻击为**分布式拒绝服务攻击DDoS** (Distributed Denial of Service)。

- **1. 传统拒绝服务攻击的分类**

拒绝服务攻击有许多种，网络的**内外部用户都可以发动这种攻击**。内部用户可以通过**长时间占用系统的内存、CPU处理时间**使其他用户不能及时得到这些资源，而引起拒绝服务攻击；外部黑客也可以通过占用网络连接使其他用户得不到网络服务。

外部用户针对网络连接发动拒绝服务攻击主要有以下几种模式：**消耗资源、破坏或更改配置信息、物理破坏或改变网络部件、利用服务程序中的处理错误使服务失效**。



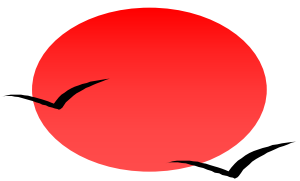
9.5.2 拒绝服务攻击与防御

■ 2. 分布式拒绝服务攻击DDoS

分布式拒绝服务DDoS攻击是传统DoS攻击的发展，攻击者首先侵入并控制一些计算机，然后控制这些计算机同时向一个特定的目标发起拒绝服务攻击。克服了传统DOS受网络资源的限制和隐蔽性两大缺点。

■ 3. 拒绝服务攻击的防御方法

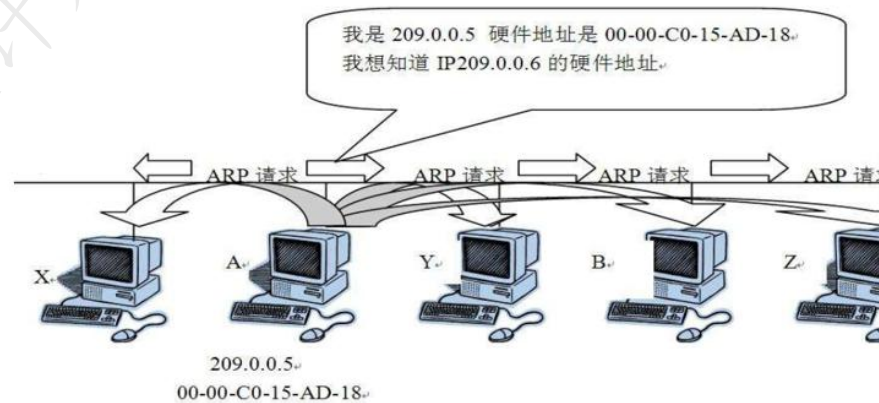
- (1) 加强对数据包的特征识别，攻击者发送的数据包中是有一些特征字符串。通过搜寻这些特征字符串，就可以确定攻击服务器和攻击者的位置。
- (2) 设置防火墙监视本地主机端口的使用情况。如果发现端口处于监听状态，则系统很可能受到攻击。
- (3) 对通信数据量进行统计也可获得有关攻击系统的位置和数量信息。在攻击时，攻击数据的来源地址会发出超出正常极限的数据量。
- (4) 尽可能的修正已经发现的问题和系统漏洞。



9.5.3 欺骗攻击与防御

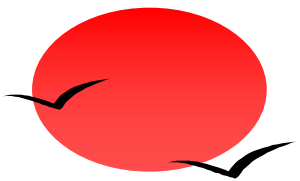
■ 1. ARP欺骗

● **正常ARP原理**：如图所示，主机A想知道局域网内主机B的MAC地址，那么主机A就广播发送ARP请求分组，局域网内主机都会收到，但只有B收到解析后知道是请求自己的MAC地址，所以只有B会返回单播的响应分组，告诉A自己的MAC地址。A收到响应分组后，会建立或更新B的IP地址和MAC地



址映射（ARP缓存表），这个映射是动态存在的，如果一定时间A、B不再通信，那么就会清空这个地址映射，下次如果还要通信，则重复这个过程。

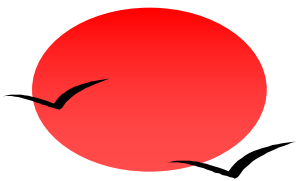
● **ARP欺骗原理**：上述过程主机A不管其有没有发送过请求广播分组，而只要收到了返回的分组信息，就会刷新IP地址和MAC地址的映射关系，这样就存在安全隐患，假设有主机C，模拟返回分组格式，构造正确的IP地址和自己的MAC地址映射，A收到后也会刷新映射关系，那么当A再次向B发送信息时，实际就发送到了C的MAC地址，数据就被C监听到了。



9.5.3 欺骗攻击与防御

- ARP欺骗的防范措施

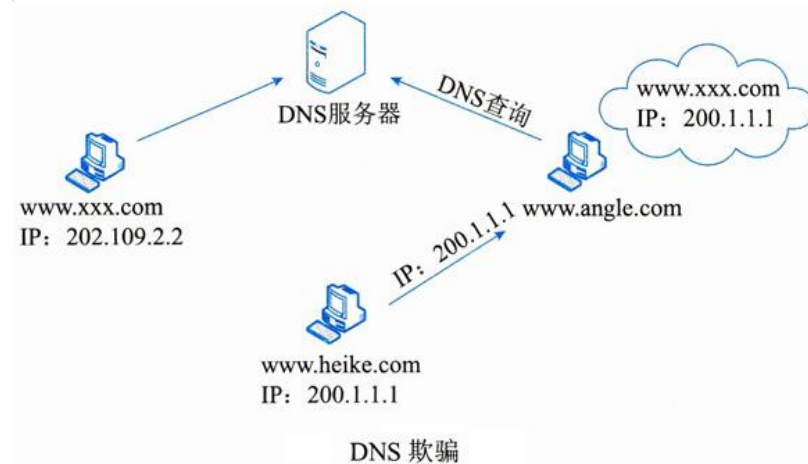
- (1) 在 WinXP下输入命令：arp -s gate-way-ip gate-way-mac 固化ARP表，阻止ARP欺骗。
- (2) 使用ARP服务器。通过该服务器查找自己的ARP转换表来响应其他机器的ARP广播。确保这台ARP服务器不被黑。
- (3) 采用双向绑定的方法解决并且防止ARP欺骗。
- (4) ARP防护软件—ARP Guard。



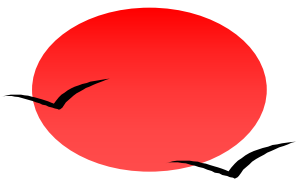
9.5.3 欺骗攻击与防御

■ 2. DNS欺骗

●**DNS欺骗原理**：DNS欺骗首先是冒充域名服务器，然后把查询的IP地址设置为攻击者的IP地址，这样的话，用户上网就只能看到攻击者的主页，而不是用户想要取得的网站主页了，这就是DNS欺骗的基本原理。即改掉了域名和IP地址的对应关系。黑客是通过冒充DNS服务器回复查询IP的。



●**DNS欺骗过程**：如图所示，www.xxx.com的IP地址为202.109.2.2，如果www.angel.com向xxx.com的子域名DNS服务器查询www.xxx.com的IP地址时，www.heike.com冒充DNS向www.angel.com回复www.xxx.com的IP地址为200.1.1.1，这时www.angel.com就会把200.1.1.1当做www.xxx.com对应的IP地址了。当www.angel.com连接www.xxx.com时，就会转向虚假的IP地址200.1.1.1，这样对www.xxx.com来说，就算是给黑掉了。



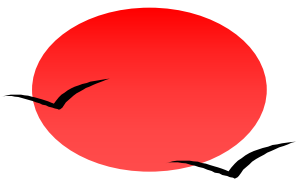
9.5.3 欺骗攻击与防御

●**DNS欺骗的检测**：根据检测手段的不同，可分为**被动监听检测**、**虚假报文探测**和**交叉检查查询**3种。

(1) **被动监听检测**：通过**旁路监听的方式**，捕获所有DNS请求和应答数据包，并为其建立一个请求应答映射表。如果在一定的时间间隔内，**一个请求对应两个或两个以上结果不同的应答包**，则怀疑受到了DNS欺骗攻击。

(2) **虚假报文探测**：采用**主动发送探测包**的手段来检测网络内是否存在DNS欺骗攻击者。如果向一个**非DNS服务器发送请求包**，正常来说不会收到任何应答，如果收到了应答包，则说明受到了攻击。

(3) **交叉检查查询**：在客户端收到DNS应答包之后，向DNS服务器**反向查询**应答包中返回的IP地址所对应的DNS名字，如果两者一致，说明没有受到攻击，否则说明被欺骗。



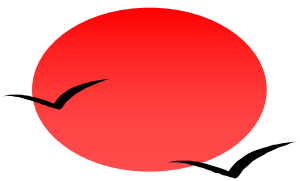
9.5.3 欺骗攻击与防御

■ 3. IP欺骗

●IP欺骗原理和过程:

- ①首先使被冒充主机host b的网络暂时瘫痪，以免对攻击造成干扰；
- ②然后连接到目标机host a的某个端口来猜测ISN初始值和增加规律；
- ③接下来把源地址伪装成被冒充主机host b，发送带有SYN标志的数据段请求连接；
- ④然后等待目标机host a发送SYN+ACK包给已经瘫痪的主机，因为现在看不到这个包；
- ⑤最后再次伪装成主机host b向目标主机host a发送ACK确认标志，此时发送的数据段带有预测的目标机的ISN+1；
- ⑥连接建立，发送命令请求。

●IP欺骗的防范：虽然IP欺骗攻击有着相当难度，但这种攻击非常广泛，入侵往往由这里开始。预防这种攻击可以删除UNIX中所有的/etc/hosts.equiv、/etc/rhosts文件，修改/etc/inetd.conf文件，使得RPC机制无法应用。另外，还可以通过设置防火墙过滤来自外部而信源地址却是内部IP的报文。



9.5.4 端口扫描

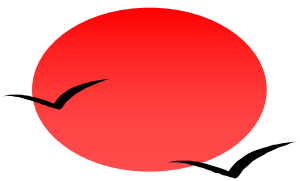
- 端口扫描是入侵者搜集信息的几种常用手法之一，通过扫描端口可以判断目标主机上开放了哪些服务以及判断主机的操作系统。

- 1. 端口扫描原理

端口扫描就是尝试与目标主机的某些端口建立连接，如果目标主机该端口有回复(见三次握手中的第二次)，则说明该端口开放，即为“活动端口”。

- 2. 端口扫描原理分类

- (1) 全TCP连接。这种扫描方法使用三次握手，与目标计算机建立标准的TCP连接。
- (2) 半打开式扫描(SYN扫描)。扫描主机自动向目标计算机的指定端口发送SYN数据段，表示发送建立连接请求。
- (3) FIN扫描。依靠发送FIN来判断目标计算机的指定端口是否是活动的。这种扫描不涉及任何TCP连接部分。因此，这种扫描比前两种都安全，可以称之为秘密扫描。
- (4) 第三方扫描。第三方扫描又称“代理扫描”，这种扫描是利用第三方主机（安全防御系数极低的个人计算机）来代替入侵者进行扫描。



9.5.5 强化TCP/IP堆栈以抵御拒绝服务攻击

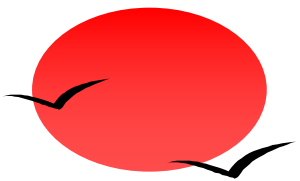
- 针对TCP/IP堆栈的攻击方式有多种类型，下面分别介绍攻击原理及抵御方法。

- **1. 同步包风暴（SYN Flooding）**

利用TCP协议缺陷发送大量伪造的TCP连接请求，使得被攻击者资源耗尽。三次握手，进行了两次，不进行第三次握手，连接队列处于等待状态，大量这样的等待，会占满全部队列空间，使得系统挂起。可以通过修改注册表防御SYN Flooding攻击。

- **2. ICMP攻击**

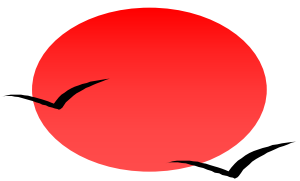
ICMP协议本身的特点决定了它非常容易被用于攻击网络上的路由器和主机。比如，前面提到的“Ping of Death”攻击就是利用操作系统规定的ICMP数据包的最大尺寸不超过64KB这一规定，达到使TCP/IP堆栈崩溃、主机死机的效果。可以通过修改注册表防御ICMP攻击。



9.5.5 强化TCP/IP堆栈以抵御拒绝服务攻击

■ 3. SNMP攻击

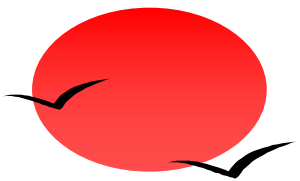
SNMP还能被用于控制这些设备和产品，重定向通信流，改变通信数据包的优先级，甚至断开通信连接。总之，入侵者如果具备相应能力，就能完全接管你的网络。可以通过修改注册表项防御。系统漏洞扫描指对重要计算机信息系统进行检查，发现其中可能被黑客利用的漏洞。包括基于网络的漏洞扫描(通过网络远程扫描主机)、基于主机的漏洞扫描(在目标系统安装了代理扫描)。



9.5.6 系统漏洞扫描

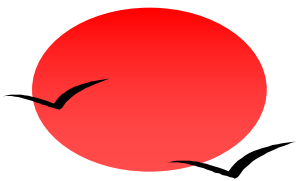
- **系统漏洞扫描**指对重要计算机信息系统进行检查，发现其中可能被黑客利用的漏洞。包括基于网络的漏洞扫描(通过网络远程扫描主机)、基于主机的漏洞扫描(在目标系统安装了代理扫描)。

诸葛老师系统架构设计



本节练习

- (5)SYN Flooding攻击的原理是_____。
 - A.利用TCP三次握手，恶意造成大量TCP半连接，耗尽服务器资源，导致系统拒绝服务
 - B.操作系统在实现TCP / IP协议栈时，不能很好地处理TCP报文的序列号紊乱问题，导致系统崩溃
 - C.操作系统在实现TCP / IP协议栈时，不能很好地处理IP分片包的重叠情况，导致系统崩溃
 - D.操作系统协议栈在处理IP分片时，对于重组后超大的IP数据包不能很好地处理，导致缓存溢出而系统崩溃
- 答案：A
- 解析：同步包风暴（SYN Flooding）利用TCP协议缺陷发送大量伪造的TCP连接请求，使得被攻击者资源耗尽。三次握手，进行了两次，不进行第三次握手，连接队列处于等待状态，大量这样的等待，会占满全部队列空间，使得系统挂起。可以通过修改注册表防御SYN Flooding攻击。



9.6 信息安全的保障体系与评估方法-9.6.1 计算机信息系统安全保护等级

■ 《计算机信息系统安全保护等级划分准则》（GB17859—999）标准规定了计算机系统安全保护能力的五个等级：

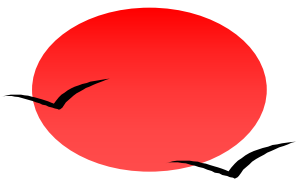
（1）**第一级 用户自主保护级**：本级的计算机信息系统可信计算基通过隔离用户与数据，使用户具备自主安全保护的能力。实施的是自主访问控制。

（2）**第二级 系统审计保护级**：本级的计算机信息系统可信计算基（Trusted Computing Base）实施了粒度更细的自主访问控制，它通过登录规程、审计安全性相关事件和隔离资源，使用户对自己的行为负责。在自主访问控制的基础上控制访问权限扩散。

（3）**第三级 安全标记保护级**：本级的计算机信息系统可信计算基具有系统审计保护级所有功能。此外，还提供有关安全策略模型、数据标记以及主体对客体强制访问控制的非形式化描述；具有准确地标记输出信息的能力；消除通过测试发现的任何错误。主要特征是计算机信息系统可信计算基对所有主体及其所控制的客体(例如：进程、文件、段、设备)实施强制访问控制。

（4）**第四级 结构化保护级**：本级的计算机信息系统可信计算基建立于一个明确定义的形式化安全策略模型之上，它要求将第三级系统中的自主和强制访问控制扩展到所有主体与客体。此外，还要考虑隐蔽通道。对外部主体能够直接或间接访问的所有资源(例如：主体、存储客体和输入输出资源)实施强制访问控制。

（5）**第五级 访问验证保护级**：本级的计算机信息系统可信计算基满足访问监控器需求。访问监控器仲裁主体对客体的全部访问。访问监控器本身是抗篡改的；必须足够小，能够分析和测试。与第四级相比，自主访问控制机制根据用户指定方式或默认方式，阻止非授权用户访问客体。访问控制的粒度是单个用户。访问控制能够为每个命名客体指定命名用户和用户组，并规定他们对客体的访问模式。没有存取权的用户只允许由授权用户指定对客体的访问权。



9.6.2 安全风险风险管理

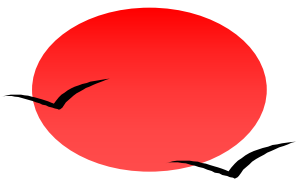
- 信息系统的安全风险，是指由于系统存在的脆弱性，人为或自然的威胁导致安全事件发生所造成的影响。在风险评估实施前，应该考虑：（1）确定风险评估的范围；（2）确定风险评估的目标；（3）建立适当的组织结构；（4）建立系统性的风险评估方法；（5）获得最高管理者对风险评估策划的批准。
- 风险评估的基本要素为脆弱性、资产、威胁、风险和安全措施，与这些要素相关的属性分别为业务战略、资产价值、安全需求、安全事件和残余风险，这些也是风险评估要素的一部分。
- 风险计算模型包含信息资产、弱点/脆弱性、威胁等关键要素。每个要素有各自的属性，信息资产的属性是资产价值，弱点的属性是弱点被威胁利用后对资产带来的影响的严重程度，威胁的属性是威胁发生的可能性。风险计算的过程如下。

（1）对信息资产进行识别，并对资产赋值。（2）对威胁进行分析，并对威胁发生的可能性赋值。

（3）识别信息资产的脆弱性，并对弱点的严重程度赋值。

（4）根据威胁和脆弱性计算安全事件发生的可能性。

（5）结合信息资产的重要性和发生安全事件的可能性，计算信息资产的风险值。



感谢

THANKS

系统架构设计师QQ群：231352210

软件设计师QQ群：759713504

诸葛老师QQ：362842353